

Cyber Threats and Vulnerabilities

Final Report — Identify and Analyze Cyber Threats

Malware Sample Analysis, Phishing Template Creation, and Real-World APT Mapping to MITRE ATT&CK

Project Name	Healthcare IAM Operations Simulation
Organization	Horizon Valley Medical Center (HVMC)
Rubric	Cyber Threats and Vulnerabilities — Identify and Analyze Cyber Threats
Analysis Lab Host	HVMC-KALI (Kali Linux)
Document Version	1.0
Prepared By	Sabitha S Karanavar
Report Date	September 3, 2026

1. Rubric Cross-Reference

This report consolidates all three required components of the “Identify and Analyze Cyber Threats” rubric line into a single submission.

Rubric Requirement	Section	Evidence
Malware sample analysis (VirusTotal)	Section 2	VirusTotal detection report, 22/60 vendors — JOMANGY/INJ3CTOR3 sample
Phishing template (SET, Kali Linux)	Section 3	setoolkit Credential Harvester build + captured login attempt
1 real APT campaign mapped to MITRE ATT&CK	Section 4	Orangeworm (G0071) / Kwampirs (S0236) — 10-technique mapping

2. Malware Sample Analysis (VirusTotal)

Condensed from the full companion report, `Malware_Diagnosis_Report_JOMANGY_679515b3.docx`, which contains the complete indicator list, behavioral write-up, and remediation guidance.

2.1 Sample Identification

SHA-256	679515b3d6642a102f3c8bb69c0884912bc700d2a575e2595752e8b446e39c00
File type / size	Bash shell script, 48.90 KB
Sample source	MalwareBazaar (abuse.ch)
Embedded C2	<code>http://160.119.69.4/x</code> (payload retrieval via curl)
Popular threat label	trojan.bash/jomangy
Family labels	bash, jomangy, kpvdmu

2.2 Detection Results

VirusTotal's community score flagged the file as malicious with 22 of 60 security vendors detecting it. VirusTotal's automated Code Insights summary independently identified the script as performing unauthorized administrative and system-level modifications targeting FreePBX/Asterisk VoIP environments, including retrieval and execution of a remote payload via curl. The detect-debug-environment signature tag indicates built-in anti-analysis / sandbox-evasion logic.

2.3 Behavioral Indicators

- Multi-stage payload: Stage 1 Bash dropper → Stage 2 JOMANGY PHP web shell → Stage 3 ZenharR web shell variant.
- Six-layer self-healing persistence: cron polling every 1–3 minutes, shell-profile injection, immutable (chattr +i) crontab backups, a process watchdog, redundant web-shell copies, and a self-reinstalling PHP executor.
- Up to 18 backdoor OS/DB accounts (9 root-equivalent) named to mimic legitimate FreePBX/Asterisk services.
- Defense evasion via double-layer (Base64-over-ROT13) obfuscation, targeted log scrubbing, and eviction of ~50 competing web-shell families.

2.4 Potential Impact

Primary monetization is VoIP toll fraud — routing unauthorized, billable calls through the victim's SIP trunks (global telecom fraud losses estimated at \$41.8B annually, CFA 2025). Secondary impact includes full root-level compromise independent of the original entry vulnerability, loss of forensic visibility through log scrubbing, and a persistence architecture that survives partial remediation — patching the entry CVE alone does not remove the infection. Attribution: JOMANGY is attributed with high confidence to the threat actor INJ3CTOR3, based on six overlapping artifacts across campaigns documented by Cyble, The Cyber Express, and prior Fortinet/Unit 42/Check Point/SANS ISC research.

3. Phishing Template Creation (Social Engineering Toolkit)

Built and demonstrated on HVMC-KALI using the Social-Engineering Toolkit's Credential Harvester Attack Method against a cloned Google login page, per the following menu path:

setoolkit → Social-Engineering Attacks → Website Attack Vectors → Credential Harvester Attack Method → Web Templates → Google

3.1 Captured Evidence

The harvester intercepted a submitted login from a client on the lab network, capturing indicators consistent with a real Google authentication flow: a GALX anti-CSRF token, the service=iso parameter, a POST to /ServiceLoginAuth, and a "POSSIBLE USERNAME/PASSWORD FIELD FOUND" detection line in the terminal output.

[Figure 1 — SET Credential Harvester terminal capture: to be inserted once the screenshot is provided]

3.2 Relevance

This phishing template is the documented initial-access assumption used in the companion tabletop exercise (HVMC_Tabletop_IR_JOMANGY_Scenario.docx), which frames a hypothetical JOMANGY-style compromise of the HVMC lab as beginning with a successful phishing capture rather than a direct internet-facing exploit — consistent with IAMLab-Net's outbound-only, no-inbound-route design.

4. Real APT Campaign Mapped to MITRE ATT&CK

Campaign selected: Orangeworm (MITRE Group ID G0071), a real, MITRE-tracked threat actor that has specifically targeted healthcare-sector organizations in the United States, Europe, and Asia since at least 2015, likely for corporate espionage — including compromises of machines running software for high-tech imaging devices such as X-ray and MRI equipment. Orangeworm's signature tool is the Kwampirs backdoor Trojan (MITRE Software ID S0236). This campaign is deliberately distinct

from the JOMANGY sample analyzed in Section 2, so this requirement is a genuine second, independent example rather than a restatement of the malware analysis.

4.1 Technique Mapping (MITRE ATT&CK for Enterprise)

Tactic	Technique	Reported Use
Discovery	T1087.001 – Account Discovery: Local Account	Kwampirs collects a list of accounts with the command net users.
Discovery	T1135 – Network Share Discovery	Kwampirs collects a list of network shares with net share.
Discovery	T1018 – Remote System Discovery	Kwampirs collects a list of available servers with net view.
Discovery	T1082 – System Information Discovery	Kwampirs collects OS/version/hostname/patch data via systeminfo, hostname, ver, and related commands.
Discovery	T1016 – System Network Configuration Discovery	Kwampirs collects adapter/interface info via ipconfig /all, arp -a, and route print.
Persistence	T1543.003 – Create or Modify System Process: Windows Service	Kwampirs creates a new service named WmiApSrvEx to establish persistence.
Defense Evasion	T1036.004 – Masquerading: Masquerade Task or Service	The persistence service is displayed as “WMI Performance Adapter Extension” to masquerade as a legitimate WMI service.
Defense Evasion	T1027.001 – Obfuscated Files or Information: Binary Padding	Kwampirs inserts a randomly generated string into its decrypted payload before writing to disk, to evade hash-based detection.
Lateral Movement	T1021.002 – Remote Services: SMB/Windows Admin Shares	Orangeworm/Kwampirs copies its backdoor across open network shares (ADMIN\$, C\$, D\$, E\$) to move laterally.
Command and Control	T1008 – Fallback Channels	Kwampirs cycles through a large, hardcoded list of C2 servers until a successful connection is established.

4.2 Documented Gap

MITRE ATT&CK does not currently attribute a confirmed Initial Access technique to Orangeworm — this is a documented gap in public reporting, not an oversight in this mapping, and is noted here rather than guessed.

5. Conclusion

All three components of the Identify and Analyze Cyber Threats rubric are satisfied: a real-world malware sample was analyzed via VirusTotal with documented detection results, behavioral indicators, and potential impact (Section 2); a functioning phishing template was built and demonstrated with SET on Kali Linux (Section 3); and a real, independently-sourced APT campaign (Orangeworm / Kwampirs) was mapped to ten MITRE ATT&CK techniques spanning Discovery, Persistence, Defense Evasion, Lateral Movement, and Command and Control (Section 4).

6. References / Sources

- VirusTotal file report — SHA-256 679515b3d6642a102f3c8bb69c0884912bc700d2a575e2595752e8b446e39c00 (analyzed September 2, 2026).

- Malware_Diagnosis_Report_JOMANGY_679515b3.docx — full companion malware analysis.
- HVMC_Tabletop_IR_JOMANGY_Scenario.docx — tabletop IR exercise referencing this phishing template as the initial-access assumption.
- MITRE ATT&CK, “Orangeworm, Group G0071,” attack.mitre.org/groups/G0071/ (retrieved September 3, 2026).
- MITRE ATT&CK, “Kwampirs, Software S0236,” attack.mitre.org/software/S0236/ (retrieved September 3, 2026).
- Symantec Security Response, “New Orangeworm attack group targets the healthcare sector in the U.S., Europe, and Asia,” 2018.

Prepared for: Sabitha — Healthcare IAM Operations Home Lab | Cyber Threats and Vulnerabilities rubric — Identify and Analyze Cyber Threats (final consolidated report)